

Under the FedRAMP Moderate baseline, RA-7 (RA-7 Risk Response): FedRAMP Moderate Baseline · RA-7 · Risk Response Control Statement: Respond to findings from security and privacy assessments, monitoring, and audits in accordance with organizational risk tolerance. Supplemental Guidance: Respond to findings from security and privacy assessments, monitoring, and audits in accordance with organizational risk tolerance. Organizations have many options for responding to risk including mitigating risk by implementing new controls or strengthening existing control

analytics capabilities are typically supported by artificial intelligence concepts and machine learning. Examples include automated threat discovery and response (which includes broad-based collection, context-based analysis, and adaptive response capabilities), automated workflow operations, and machine-assisted decision tools. However, sophisticated adversaries may be able to extract information related to analytic parameters and retrain the machine learning to classify malicious activity as benign. Accordingly, machine learning is augmented by human monitoring to help ensure that sophisticated adversaries are not able to conceal their activities. This requirement enhances SP 800-171 requirement 03.11.01. PROTECTION STRATEGY DLO ADVERSARY EFFECTS Preclude (Expunge), Limit (Shorten, Reduce), Expose (Detect, Scrutinize) REFERENCES Source Control: RA-03(04) 03.11.04E Withdrawn Addressed by 03.15.01E, 03.11.01 (SP 800-171), 03.11.04 (SP 800-171), and 03.15.02 (SP 800-171). 03.11.05E Withdrawn Addressed by 03.11.01E, 03.11.03E, 03.11.01 (SP 800-171), 03.11.04 (SP 800-171), 03.12.01 (SP 800-171), and 03.12.03 (SP 800-171). 03.11.06E Withdrawn Addressed by 03.12.03E, 03.11.01 (SP 800-171), 03.11.04 (SP 800-171), 03.12.01 (SP 800-171), 03.12.03 (SP 800-171), and 03.17.03 (SP 800-171). 03.11.07E Withdrawn Addressed by 03.17.01 (SP 800-171). 03.11.08E Dynamic Threat Awareness Determine the current cyber threat environment on an ongoing basis using [Assignment: organization-defined means].

NIST SP 800-53 Rev 5 control RA-5.3 (Breadth and Depth of Coverage) summarizes the requirements for this control: RA-5.3 · Breadth and Depth of Coverage Control Statement: Define the breadth and depth of vulnerability scanning coverage. Supplemental Guidance: Define the breadth and depth of vulnerability scanning coverage. The breadth of vulnerability scanning coverage can be expressed as a percentage of components within the system, by the particular types of systems, by the criticality of systems, or by the number of vulnerabilities to be checked. Conversely, the depth of vulnerability scanning coverage

NIST SP 800-171 Rev 3 control 03.11.02 (03.11.02 Vulnerability Monitoring and Scanning) is assessed by examining the following: Assessment Objectives: - the system is monitored for vulnerabilities [organization-defined parameter]. - the system is scanned for vulnerabilities [organization-defined parameter]. - system vulnerabilities are remediated within [organization-defined parameter]. - the system is monitored for vulnerabilities when new vulnerabilities that affect the system are identified. - the system is scanned for vulnerabilities when new vulnerabilities that affect the system are identified. - system vulnerabilities to be scanned are updated [organization-defined parameter]. - system vulnerabilities to be scan

and (b) Verify that the acquisition or outsourcing of dedicated information security services is approved by [Assignment: organization-defined personnel or roles]. Discussion: Information security services include the operation of security devices, such as firewalls or key management services as well as incident monitoring, analysis, and response. Risks assessed can include system, mission or business, security, privacy, or supply chain risks. Related Controls: CA-6, RA-3, RA-8. (2) EXTERNAL SYSTEM SERVICES | IDENTIFICATION OF FUNCTIONS, PORTS, PROTOCOLS, AND SERVICES Require providers of the following external system services to identify the functions, ports, protocols, and other services required for the use of such services: [Assignment: organization-defined external system services]. CHAPTER THREE PAGE 271 This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-53r5>.

NIST SP 800-53, REV.

Under the FedRAMP Moderate baseline, RA-5.2 (RA-5.2 Update Vulnerabilities to Be Scanned): FedRAMP Moderate Baseline · RA-5.2 · Update Vulnerabilities to Be Scanned Control Statement: Update the system vulnerabilities to be scanned [organization-defined parameter]. Supplemental Guidance: Update the system vulnerabilities to be scanned [organization-defined parameter]. Due to the complexity of modern software, systems, and other factors, new vulnerabilities are discovered on a regular basis. It is important that newly discovered vulnerabilities are added to the list of vulnerabilities

NIST SP 800-53 Rev 5 control RA-10 (Threat Hunting) summarizes the requirements for this control: RA-10 · Threat Hunting Control Statement: a. Establish and maintain a cyber threat hunting capability to: 1. Search for indicators of compromise in organizational systems; and 2. Detect, track, and disrupt threats that evade existing controls; and b. Employ the threat hunting capability [organization-defined parameter]. Supplemental Guidance: a. Establish and maintain a cyber threat hunting capability to: 1. Search for indicators of compromise in organizational systems; and 2. Detect,

NIST SP 800-53 Rev 5 control RA-1 (Policy and Procedures): RA-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] risk assessment policy that: 2. Procedures to facilitate the implementation of the risk assessment policy and the associated risk assessment controls; b. Designate an [organization-defined parameter] to manage the development, documenta

NIST SP 800-53 Rev 5 control RA-5.4 (Discoverable Information) summarizes the requirements for this control: RA-5.4 · Discoverable Information Control Statement: Determine information about the system that is discoverable and take [organization-defined parameter]. Supplemental Guidance: Determine information about the system that is discoverable and take [organization-defined parameter]. Discoverable information includes information that adversaries could obtain without compromising or breaching the system, such as by collecting information that the system is exposing or by conducting extensive web s

NIST SP 800-171 Rev 3 control 03.11.02 (03.11.02 Vulnerability Monitoring and Scanning) falls under the Risk Assessment family. Control Statement: SR-03.11.02.a Monitor and scan the system for vulnerabilities [organization-defined parameter] and when new vulnerabilities affecting the system are identified. SR-03.11.02.b Remediate system vulnerabilities within [organization-defined parameter]. SR-03.11.02.c Update system vulnerabilities to be scanned [organization-defined parameter] and when new vulnerabilities are identified and reported. Supplemental Guidance: Organizations determine the required vulnerability scanning for system components and ensure that potential sources of vulnerabilities (e.g., networked printers, scanners, and copiers) are not overlooked. Vulnerability analyses for custom software may require additional approaches, such as static analysis, dynamic analysis, or binary analysis. Organizations can use these approaches in source code reviews and tools (e.g., static analysis tools, web-based application scanner

Under the FedRAMP Moderate baseline, RA-5 (RA-5 Vulnerability Monitoring and Scanning): FedRAMP Moderate Baseline · RA-5 · Vulnerability Monitoring and Scanning Control Statement: a. Monitor and scan for vulnerabilities in the system and hosted applications [organization-defined parameter] and when new vulnerabilities potentially affecting the system are identified and reported; b. Employ vulnerability monitoring tools and techniques that facilitate interoperability among tools and automate parts of the vulnerability management process by using standards for: 1. Enumerating plat

Control RA-3: ents at all three levels in the risk management hierarchy (i.e., organization level, mission/business process level, or information system level) and at any stage in the system development life cycle. Risk assessments can also be conducted at various steps in the Risk Management Framework, including preparation, categorization, control selection, control implementation, control assessment, authorization, and control monitoring. Risk assessment is an ongoing activity carried out throughout the system development life cycle. Risk assessments can also address information related to the system, including system design, the intended use of the system, testing results, and supply chain-related information or artifacts. Risk assessments can play an important role in control selection processes, particularly during the application of tailoring guidance and in the earliest phases of capability determination. Related Controls: CA-3, CA-6, CM-4, CM-13, CP-6, CP-7, IA-8, MA-5, PE-3, PE-8, PE-18, PL-2, PL- 10, PL-11, PM-8, PM-9, PM-28, PT-2, PT-7, RA-2, RA-5, RA-7, SA-8, SA-9, SC-38, SI-12. Control Enhancements: (1) RISK ASSESSMENT | SUPPLY CHAIN RISK ASSESSMENT CHAPTER THREE PAGE 240 T h s i p u b l i c a t i o n i s a v a i l a b e f r e e o f c h a r g e f r o m : <https://doi.org/10.6028/NIST.SP.800-53r5>. | NIST SP 800-53, REV.

Under the FedRAMP High baseline, RA-5.3 (RA-5.3 Breadth and Depth of Coverage): FedRAMP High Baseline · RA-5.3 · Breadth and Depth of Coverage Control Statement: Define the breadth and depth

of vulnerability scanning coverage. Supplemental Guidance: Define the breadth and depth of vulnerability scanning coverage. The breadth of vulnerability scanning coverage can be expressed as a percentage of components within the system, by the particular types of systems, by the criticality of systems, or by the number of vulnerabilities to be checked. Conversely, the depth of vulnera

NIST SP 800-53 Rev 5 control RA-9 (Criticality Analysis) summarizes the requirements for this control: RA-9 · Criticality Analysis Control Statement: Identify critical system components and functions by performing a criticality analysis for [organization-defined parameter] at [organization-defined parameter]. Supplemental Guidance: Identify critical system components and functions by performing a criticality analysis for [organization-defined parameter] at [organization-defined parameter]. Not all system components, functions, or services necessarily require significant protections. For example

NIST SP 800-171 Rev 3 control 03.11.02 (03.11.02 Vulnerability Monitoring and Scanning) is assessed by examining the following: Assessment Objectives: - the system is monitored for vulnerabilities [organization-defined parameter]. - the system is scanned for vulnerabilities [organization-defined parameter]. - system vulnerabilities are remediated within [organization-defined parameter]. - the system is monitored for vulnerabilities when new vulnerabilities that affect the system are identified. - the system is scanned for vulnerabilities when new vulnerabilities that affect the system are identified. - system vulnerabilities to be scanned are updated [organization-defined parameter]. - system vulnerabilities to be scan

03.11.02 · Vulnerability Monitoring and Scanning Control Statement: SR-03.11.02.a Monitor and scan the system for vulnerabilities [organization-defined parameter] and when new vulnerabilities affecting the system are identified. SR-03.11.02.b Remediate system vulnerabilities within [organization-defined parameter]. SR-03.11.02.c Update system vulnerabilities to be scanned [organization-defined parameter] and when new vulnerabilities are identified and reported. Supplemental Guidance: Organizations determine the required vulnerability scanning for system components and ensure that potential sources of vulnerabilities (e.g., networked printers, scanners, and copiers) are not overlooked. Vulnerability analyses for custom software may require additional approaches, such as static analysis, dynamic analysis, or binary analysis. Organizations can use these approaches in source code reviews and tools (e.g., static analysis tools, web-based application scanners, binary analyzers). Vulnerability scanning includes scanning for patch levels; scanning for functions, ports, protocols, and services that should not be accessible to users or devices; and scanning for improperly configured or incorrectly operating flow control mechanisms. To facilitate interoperability, organizations consider using scanning tools that express vulnerabilities in the Common Vulnerabilities and Exposures (CVE) naming convention. Sources for vulnerability information also include the Common Weakness Enumeration (CWE) listing, the National Vulnerability Database (NVD), and the Common Vulnerability Scoring System (CVSS). Assessment Objectives: - the system is monitored for vulnerabilities [organization-defined parameter]. - the system is scanned for vulnerabilities [organization-defined parameter]. - system vulnerabilities are remediated within [organization-defined parameter]. - the system is monitored for vulnerabilities when new vulnerabilities that affect the system are identified. - the system is scanned for vulnerabilities when new vulnerabilities that affect the system are identified. - system vulnerabilities to be scanned are updated [organization-defined parameter]. - system vulnerabilities to be scanned are updated when new vulnerabilities are identified and reported. Organization-Defined Parameters: - A.03.11.02.ODP.01: frequency - A.03.11.02.ODP.02: frequency - A.03.11.02.ODP.03: response times - A.03.11.02.ODP.04: frequency

NIST SP 800-171 Rev 3 control 03.11.01 (03.11.01 Risk Assessment) falls under the Risk Assessment family. Control Statement: SR-03.11.01.a Assess the risk (including supply chain risk) of unauthorized disclosure resulting from the processing, storage, or transmission of CUI. SR-03.11.01.b Update risk assessments [organization-defined parameter]. Supplemental Guidance: Establishing the system boundary is a prerequisite to assessing the risk of the unauthorized disclosure of CUI. Risk assessments consider threats, vulnerabilities, likelihood, and adverse impacts to organizational operations and assets based on the operation and use of the system and the unauthorized disclosure of CUI. Risk assessments also consider risks from external parties (e.g., contractors operating systems on behalf of the organization, service providers, individual

NIST SP 800-171 Rev 3 control 03.11.04 (03.11.04 Risk Response) is assessed by examining the

following: Assessment Objectives: - findings from security assessments are responded to. - findings from security monitoring are responded to. - findings from security audits are responded to.

NIST SP 800-53 Rev 5 control RA-2.1 (Impact-level Prioritization) is assessed by examining, interviewing, and testing: RA-2.1 · Impact-level Prioritization Control Statement: Conduct an impact-level prioritization of organizational systems to obtain additional granularity on system impact levels. Supplemental Guidance: Conduct an impact-level prioritization of organizational systems to obtain additional granularity on system impact levels. Organizations apply the "high-water mark" concept to each system categorized in accordance with [FIPS 199](#628d22a1-6a11-4784-bc59-5cd9497b5445) , resulting in systems desi

From the NIST SP 800-172 Rev 3 Final Public Draft: T he threat awareness information that is gathered feeds into the organization's security operations to ensure that procedures are updated in response to the changing threat environment. For example, at higher threat levels, organizations may change the privilege or authentication thresholds required to perform certain operations. This requirement enhances SP 800-171 requirement 03.11.01. PROTECTION STRATEGY DLO ADVERSARY EFFECTS Expose (Detect, Reveal) REFERENCES Source Control: RA-03(03) 03.1 1.09E Ind icators of Compromise Discover, collect, and distribute to [Assignment: organization-defined personnel or roles], indicators of compromise provided by [Assignment: organization-defined sources]. DISCUSSION Indicators of compromise (IOCs) are forensic artifacts from intrusio

Under the FedRAMP High baseline, RA-9 (RA-9 Criticality Analysis): FedRAMP High Baseline · RA-9 · Criticality Analysis Control Statement: Identify critical system components and functions by performing a criticality analysis for [organization-defined parameter] at [organization-defined parameter]. Supplemental Guidance: Identify critical system components and functions by performing a criticality analysis for [organization-defined parameter] at [organization-defined parameter]. Not all system components, functions, or services necessarily require significant

NIST SP 800-171 Rev 3 control 03.11.04 (03.11.04 Risk Response) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Risk Assessment (RA) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control RA-5.11 (Public Disclosure Program) summarizes the requirements for this control: RA-5.11 · Public Disclosure Program Control Statement: Establish a public reporting channel for receiving reports of vulnerabilities in organizational systems and system components. Supplemental Guidance: Establish a public reporting channel for receiving reports of vulnerabilities in organizational systems and system components. The reporting channel is publicly discoverable and contains clear language authorizing good-faith research and the disclosure of vulnerabilities to the organization.

Under the FedRAMP High baseline, RA-7 (RA-7 Risk Response): FedRAMP High Baseline · RA-7 · Risk Response Control Statement: Respond to findings from security and privacy assessments, monitoring, and audits in accordance with organizational risk tolerance. Supplemental Guidance: Respond to findings from security and privacy assessments, monitoring, and audits in accordance with organizational risk tolerance. Organizations have many options for responding to risk including mitigating risk by implementing new controls or strengthening existing controls, a

Physical Protection 3.10.6 Alternate Work Sites a. Determine alternate work sites allowed for use by employees. b. Employ the following security requirements at alternate work sites: [Assignment: organization- defined security requirements] (03.10.06.b). Related Controls: PE-17 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.10.06.b [Assignment: organization-defined security requirements] adequate security, comparable to organizational security requirements at the primary work site where practical, documented in policy, and covered by training Risk Assessment 3.11.1 Risk Assessment a. Assess the risk (including supply chain risk) of unauthorized disclosure resulting from the processing, storage, or transmission of CUI. b. Update risk assessments [Assignment: organization-defined frequency] (03.11.01.b). Related Controls: RA-03, RA-03(01), SR-06 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.11.01.b [Assignment: organization- defined frequency] at least every 12 months, or when there are significant1

incidents or significant changes to risks

NIST SP 800-53 Rev 5 control RA-5.5 (Privileged Access) summarizes the requirements for this control: RA-5.5 · Privileged Access Control Statement: Implement privileged access authorization to [organization-defined parameter] for [organization-defined parameter]. Supplemental Guidance: Implement privileged access authorization to [organization-defined parameter] for [organization-defined parameter]. In certain situations, the nature of the vulnerability scanning may be more intrusive, or the system component that is the subject of the scanning may contain classified or controlled unclassified

NIST SP 800-53 Rev 5 control RA-8 (Privacy Impact Assessments) is assessed by examining, interviewing, and testing: RA-8 · Privacy Impact Assessments Control Statement: Conduct privacy impact assessments for systems, programs, or other activities before: a. Developing or procuring information technology that processes personally identifiable information; and b. Initiating a new collection of personally identifiable information that: 1. Will be processed using information technology; and 2. Includes personally identifiable information permitting the physical or virtual (online) contacting of a specific in

NIST SP 800-53 Rev 5 control RA-3 (Risk Assessment) summarizes the requirements for this control: RA-3 · Risk Assessment Control Statement: a. Conduct a risk assessment, including: 1. Identifying threats to and vulnerabilities in the system; 2. Determining the likelihood and magnitude of harm from unauthorized access, use, disclosure, disruption, modification, or destruction of the system, the information it processes, stores, or transmits, and any related information; and 3. Determining the likelihood and impact of adverse effects on individuals arising from the processing of persona

Under the FedRAMP Low baseline, RA-2 (RA-2 Security Categorization): FedRAMP Low Baseline · RA-2 · Security Categorization Control Statement: a. Categorize the system and information it processes, stores, and transmits; b. Document the security categorization results, including supporting rationale, in the security plan for the system; and c. Verify that the authorizing official or authorizing official designated representative reviews and approves the security categorization decision. Supplemental Guidance: a. Categorize the system and information it processes

NIST SP 800-171 Rev 3 control 03.11.04 (03.11.04 Risk Response) falls under the Risk Assessment family. 03.11.04 · Risk Response Supplemental Guidance: This requirement addresses the need to determine an appropriate response to risk before generating a plan of action and milestones (POAM) entry. It may be possible to mitigate the risk immediately so that a POAM entry is not needed. However, a POAM entry is generated if the risk response is to mitigate the identified risk and the mitigation cannot be completed immediately. Assessment Objectives: - findings from security assessments are responded Supplemental Guidance: This requirement addresses the need to determine an appropriate response to risk before generating a plan of action and milestones (POAM) entry. It may be possible to mitigate the risk immediately so that a POAM entry is not needed. However, a POAM entry is generated if the risk response is to mitigate the identified risk and the mitigation cannot be completed immediately.

NIST SP 800-171 Rev 3 control 03.11.04 (03.11.04 Risk Response) is assessed by examining the following: Assessment Objectives: - findings from security assessments are responded to. - findings from security monitoring are responded to. - findings from security audits are responded to.

b. Employ the threat-hunting capability [Assignment: organization-defined frequency]. DISCUSSION Threat hunting is an active means of cyber defense in contrast to traditional protection measures, such as firewalls, intrusion detection and prevention systems, quarantining malicious code in sandboxes, and Security Information and Event Management (SIEM) technologies and systems. Cyber threat hunting involves proactively searching organizational systems, networks, and infrastructure for advanced threats. The objective is to track and disrupt adversaries as early as possible in the attack sequence and to measurably improve the speed and accuracy of responses. Indications of compromise include unusual network traffic, unusual file changes, and the presence of malicious code. Threat-hunting teams leverage existing threat intelligence and may create new threat intelligence that is shared with peer organizations, Information Sharing and Analysis Organizations (ISAO), Information Sharing and Analysis Centers (ISAC), and relevant government departments and agencies. This requirement does not enhance a specific requirement in SP 800-171 but can be used to

strengthen the protection of CUI associated with critical programs or high value assets. PROTECTION STRATEGY DLO ADVERSARY EFFECTS Preclude (Expunge), Limit (Shorten, Reduce), Expose (Detect, Scrutinize) REFERENCES Source Control: RA-10 03.1 1.03E Predictive Cyber Analytics Employ the following advanced automation and analytics capabilities to predict and identify risks to [Assignment: organization-defined systems or system components]: [Assignment: organization-defined advanced automation and analytics capabilities]. DISCUSSION A properly resourced security operations center (SOC) or computer incident response team (CIRT) may be overwhelmed by the volume of information generated by the proliferation of security tools and appliances unless it employs advanced automation and analytics to analyze the data. Advanced automation and predictive

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 REQUIREMENT NUMBER ENHANCED SECURITY REQUIREMENT REQUIREMENT TYPE 03.09.02E Withdrawn 03.09.03E Access Agreements T SP 800-53, PS-06 03.09.04E Citizenship Requirements E 03.09.01 Physical Protection 03.10.01E Intrusion Alarms and Surveillance Equipment E 03.10.02 03.10.02E Delivery and Removal of System Components S SP 800-53, PE-16 Risk Assessment 03.11.01E Threat Awareness Program S SP 800-53, PM-16 03.11.02E Threat Hunting S SP 800-53, RA-10 03.11.03E Predictive Cyber Analytics E 03.11.01 03.11.04E Withdrawn 03.11.05E Withdrawn 03.11.06E Withdrawn 03.11.07E Withdrawn 03.11.08E Dynamic Threat Awareness E 03.11.01 03.11.09E Indicators of Compromise E 03.14.06

Under the FedRAMP Moderate baseline, RA-2 (RA-2 Security Categorization): FedRAMP Moderate Baseline · RA-2 · Security Categorization Control Statement: a. Categorize the system and information it processes, stores, and transmits; b. Document the security categorization results, including supporting rationale, in the security plan for the system; and c. Verify that the authorizing official or authorizing official designated representative reviews and approves the security categorization decision. Supplemental Guidance: a. Categorize the system and information it proc

NIST SP 800-53 Rev 5 control RA-5.2 (Update Vulnerabilities to Be Scanned) is assessed by examining, interviewing, and testing: RA-5.2 · Update Vulnerabilities to Be Scanned Control Statement: Update the system vulnerabilities to be scanned [organization-defined parameter]. Supplemental Guidance: Update the system vulnerabilities to be scanned [organization-defined parameter]. Due to the complexity of modern software, systems, and other factors, new vulnerabilities are discovered on a regular basis. It is important that newly discovered vulnerabilities are added to the list of vulnerabilities to be scanned to ensure th

NIST SP 800-53 Rev 5 control RA-10 (Threat Hunting) is assessed by examining, interviewing, and testing: RA-10 · Threat Hunting Control Statement: a. Establish and maintain a cyber threat hunting capability to: 1. Search for indicators of compromise in organizational systems; and 2. Detect, track, and disrupt threats that evade existing controls; and b. Employ the threat hunting capability [organization-defined parameter]. Supplemental Guidance: a. Establish and maintain a cyber threat hunting capability to: 1. Search for indicators of compromise in organizational systems; and 2. Detect,

Under the FedRAMP High baseline, RA-3.1 (RA-3.1 Supply Chain Risk Assessment): FedRAMP High Baseline · RA-3.1 · Supply Chain Risk Assessment Control Statement: (a) Assess supply chain risks associated with [organization-defined parameter] ; and (b) Update the supply chain risk assessment [organization-defined parameter] , when there are significant changes to the relevant supply chain, or when changes to the system, environments of operation, or other conditions may necessitate a change in the supply chain. Supplemental Guidance: (a) Assess supply chain risks associated

RA-8 · Privacy Impact Assessments Control Statement: Conduct privacy impact assessments for systems, programs, or other activities before: a. Developing or procuring information technology that processes personally identifiable information; and b. Initiating a new collection of personally identifiable information that: 1. Will be processed using information technology; and 2. Includes personally identifiable information permitting the physical or virtual (online) contacting of a specific individual, if identical questions have been posed to, or identical reporting requirements imposed on, ten or more individuals, other than agencies, instrumentalities, or employees of the federal government. Supplemental Guidance: Conduct privacy impact assessments for systems, programs, or other activities before: a. Developing or procuring information technology that processes personally identifiable information; and b. Initiating a new collection of personally

identifiable information that: 1. Will be processed using information technology; and 2. Includes personally identifiable information permitting the physical or virtual (online) contacting of a specific individual, if identical questions have been posed to, or identical reporting requirements imposed on, ten or more individuals, other than agencies, instrumentalities, or employees of the federal government. A privacy impact assessment is an analysis of how personally identifiable information is handled to ensure that handling conforms to applicable privacy requirements, determine the privacy risks associated with an information system or activity, and evaluate ways to mitigate privacy risks. A privacy impact assessment is both an analysis and a formal document that details the process and the outcome of the analysis. Organizations conduct and develop a privacy impact assessment with sufficient clarity and specificity to demonstrate that the organization fully considered privacy and incorporated appropriate privacy protections from the earliest stages of the organization's activity and throughout the information life cycle. In order to conduct a meaningful privacy impact assessment, the organization's senior agency official for privacy works closely with program managers, system owners, information technology experts, security officials, counsel, and other relevant organization personnel. Moreover, a privacy impact assessment is not a time-restricted activity that is limited to a particular milestone or stage of the information system or personally identifiable information life cycles. Rather, the privacy analysis continues throughout the system and personally identifiable information life cycles. Accordingly, a privacy impact assessment is a living document that organizations update whenever changes to the information technology, changes to the organization's practices, or other factors alter the privacy risks associated with the use of such information technology. To conduct the privacy impact assessment, organizations can use security and privacy risk assessments. Organizations may also use other related processes that may have different names, including privacy threshold analyses. A privacy impact assessment can also serve as notice to the public regarding the organization's practices with respect to privacy. Although conducting and publishing privacy impact assessments may be required by law, organizations may develop such policies in the absence of applicable laws. For federal agencies, privacy impact assessments may be required by [EGOV](#7b0b9634-741a-4335-b6fa-161228c3a76e) ; agencies should consult with their senior agency official for privacy and legal counsel on this requirement and be aware of the statutory exceptions and OMB guidance relating to the provision.

Under the FedRAMP High baseline, RA-5.5 (RA-5.5 Privileged Access): FedRAMP High Baseline · RA-5.5 · Privileged Access Control Statement: Implement privileged access authorization to [organization-defined parameter] for [organization-defined parameter]. Supplemental Guidance: Implement privileged access authorization to [organization-defined parameter] for [organization-defined parameter]. In certain situations, the nature of the vulnerability scanning may be more intrusive, or the system component that is the subject of the scanning may contain classified or

NIST SP 800-53 Rev 5 control RA-5.10 (Correlate Scanning Information) is assessed by examining, interviewing, and testing: RA-5.10 · Correlate Scanning Information Control Statement: Correlate the output from vulnerability scanning tools to determine the presence of multi-vulnerability and multi-hop attack vectors. Supplemental Guidance: Correlate the output from vulnerability scanning tools to determine the presence of multi-vulnerability and multi-hop attack vectors. An attack vector is a path or means by which an adversary can gain access to a system in order to deliver malicious code or exfiltrate information.

Under the FedRAMP Moderate baseline, RA-3.1 (RA-3.1 Supply Chain Risk Assessment): FedRAMP Moderate Baseline · RA-3.1 · Supply Chain Risk Assessment Control Statement: (a) Assess supply chain risks associated with [organization-defined parameter] ; and (b) Update the supply chain risk assessment [organization-defined parameter] , when there are significant changes to the relevant supply chain, or when changes to the system, environments of operation, or other conditions may necessitate a change in the supply chain. Supplemental Guidance: (a) Assess supply chain risks associa

NIST SP 800-171 Rev 3 control 03.11.04 (03.11.04 Risk Response) requires organizations to implement the following: 03.11.04 · Risk Response Supplemental Guidance: This requirement addresses the need to determine an appropriate response to risk before generating a plan of action and milestones (POAM) entry. It may be possible to mitigate the risk immediately so that a POAM entry is not needed. However, a POAM entry is generated if the risk response is to mitigate the identified risk and the mitigation cannot be completed immediately. Assessment Objectives: - findings from security assessments are responded For practical implementation, organizations should document their

approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.11.04.

NIST SP 800-53 Rev 5 control RA-5.5 (Privileged Access) is assessed by examining, interviewing, and testing: RA-5.5 · Privileged Access Control Statement: Implement privileged access authorization to [organization-defined parameter] for [organization-defined parameter]. Supplemental Guidance: Implement privileged access authorization to [organization-defined parameter] for [organization-defined parameter]. In certain situations, the nature of the vulnerability scanning may be more intrusive, or the system component that is the subject of the scanning may contain classified or controlled unclassified

03.11.04 · Risk Response Supplemental Guidance: This requirement addresses the need to determine an appropriate response to risk before generating a plan of action and milestones (POAM) entry. It may be possible to mitigate the risk immediately so that a POAM entry is not needed. However, a POAM entry is generated if the risk response is to mitigate the identified risk and the mitigation cannot be completed immediately. Assessment Objectives: - findings from security assessments are responded to. - findings from security monitoring are responded to. - findings from security audits are responded to.

NIST SP 800-171 Rev 3 control 03.11.01 (03.11.01 Risk Assessment) is assessed by examining the following: Assessment Objectives: - the risk (including supply chain risk) of unauthorized disclosure resulting from the processing, storage, or transmission of CUI is assessed. - risk assessments are updated [organization-defined parameter].

and b. Employ the threat hunting capability [Assignment: organization-defined frequency]. Discussion: Threat hunting is an active means of cyber defense in contrast to traditional protection measures, such as firewalls, intrusion detection and prevention systems, quarantining malicious code in sandboxes, and Security Information and Event Management technologies and systems. Cyber threat hunting involves proactively searching organizational systems, networks, and infrastructure for advanced threats. The objective is to track and disrupt cyber adversaries as early as possible in the attack sequence and to measurably improve the speed and accuracy of organizational responses. Indications of compromise include unusual network traffic, unusual file changes, and the presence of malicious code. Threat hunting teams leverage existing threat intelligence and may create new threat intelligence, which is shared with peer organizations, Information Sharing and Analysis Organizations (ISAO), Information Sharing and Analysis Centers (ISAC), and relevant government departments and agencies. This publication is Related Controls: CA-2, CA-7, CA-8, RA-3, RA-5, RA-6, SI-4. available free of charge from: <https://doi.org/10.6028/NIST.SP.800-53r5>. Control Enhancements: None. References: [SP 800-30].

and scanning for flow control mechanisms that are improperly configured or operating incorrectly. Vulnerability CHAPTER THREE PAGE 242 This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-53r5>

. NIST SP 800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

monitoring may also include continuous vulnerability monitoring tools that use instrumentation to continuously analyze components. Instrumentation-based tools may improve accuracy and may be run throughout an organization without scanning. Vulnerability monitoring tools that facilitate interoperability include tools that are Security Content Automated Protocol (SCAP)- validated.

Under the FedRAMP Low baseline, RA-1 (RA-1 Policy and Procedures): FedRAMP Low Baseline · RA-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] risk assessment policy that: 2. Procedures to facilitate the implementation of the risk assessment policy and the associated risk assessment controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the risk assessment policy and procedures; and c.

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Related Controls: RA-03, RA-03(01), SR-06 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.11.01.b [Assignment: organization- defined frequency] at least every 12 months, or when there are significant1

incidents or significant changes to risks Risk Assessment 3.11.2 System Vulnerability Management
a. Monitor and scan the system for vulnerabilities [Assignment: organization-defined frequency]
(03.11.02.a) and when new vulnerabilities affecting the system are identified. b. Remediate system
vulnerabilities within [Assignment: organization-defined response times] (03.11.02.b). c. Update
system vulnerabilities to be scanned [Assignment: organization-defined frequency] (03.11.02.c) and
when new vulnerabilities are identified and reported. Related Controls: RA-05, RA-0

NIST SP 800-53 Rev 5 control RA-7 (Risk Response) is defined as follows: RA-7 · Risk Response
Control Statement: Respond to findings from security and privacy assessments, monitoring, and audits
in accordance with organizational risk tolerance. Supplemental Guidance: Respond to findings from
security and privacy assessments, monitoring, and audits in accordance with organizational risk
tolerance. Organizations have many options for responding to risk including mitigating risk by
implementing new controls or strengthening existing controls, accepting risk with appropriate
justification or rationale, sharing or transferring risk, or avoiding risk. The risk toleranc

NIST SP 800-171 Rev 3 control 03.11.02 (03.11.02 Vulnerability Monitoring and Scanning) requires
organizations to implement the following: Control Statement: SR-03.11.02.a Monitor and scan the
system for vulnerabilities [organization-defined parameter] and when new vulnerabilities affecting
the system are identified. SR-03.11.02.b Remediate system vulnerabilities within [organization-
defined parameter]. SR-03.11.02.c Update system vulnerabilities to be scanned [organization-defined
parameter] and when new vulnerabilities are identified and reported. For practical implementation,
organizations should document their approach in their System Security Plan (SSP) and ensure that
policies, procedures, and technical controls address each sub-requirement of 03.11.02.

RA-3.4 · Predictive Cyber Analytics Control Statement: Employ the following advanced automation and
analytics capabilities to predict and identify risks to [organization-defined parameter]:
[organization-defined parameter]. Supplemental Guidance: Employ the following advanced automation
and analytics capabilities to predict and identify risks to [organization-defined parameter]:
[organization-defined parameter]. A properly resourced Security Operations Center (SOC) or Computer
Incident Response Team (CIRT) may be overwhelmed by the volume of information generated by the
proliferation of security tools and appliances unless it employs advanced automation and analytics
to analyze the data. Advanced automation and analytics capabilities are typically supported by
artificial intelligence concepts, including machine learning. Examples include Automated Threat
Discovery and Response (which includes broad-based collection, context-based analysis, and adaptive
response capabilities), automated workflow operations, and machine assisted decision tools. Note,
however, that sophisticated adversaries may be able to extract information related to analytic
parameters and retrain the machine learning to classify malicious activity as benign. Accordingly,
machine learning is augmented by human monitoring to ensure that sophisticated adversaries are not
able to conceal their activities.

Under the FedRAMP High baseline, RA-5.8 (RA-5.8 Review Historic Audit Logs): FedRAMP High Baseline
· RA-5.8 · Review Historic Audit Logs Control Statement: Review historic audit logs to determine if
a vulnerability identified in a [organization-defined parameter] has been previously exploited
within an [organization-defined parameter]. Supplemental Guidance: Review historic audit logs to
determine if a vulnerability identified in a [organization-defined parameter] has been previously
exploited within an [organization-defined parameter]. Reviewing historic audit logs to

NIST SP 800-53 Rev 5 control RA-5.4 (Discoverable Information) is assessed by examining,
interviewing, and testing: RA-5.4 · Discoverable Information Control Statement: Determine
information about the system that is discoverable and take [organization-defined parameter].
Supplemental Guidance: Determine information about the system that is discoverable and take
[organization-defined parameter]. Discoverable information includes information that adversaries
could obtain without compromising or breaching the system, such as by collecting information that
the system is exposing or by conducting extensive web s

NIST SP 800-53 Rev 5 control RA-5.8 (Review Historic Audit Logs) summarizes the requirements for
this control: RA-5.8 · Review Historic Audit Logs Control Statement: Review historic audit logs to
determine if a vulnerability identified in a [organization-defined parameter] has been previously
exploited within an [organization-defined parameter]. Supplemental Guidance: Review historic audit
logs to determine if a vulnerability identified in a [organization-defined parameter] has been

previously exploited within an [organization-defined parameter]. Reviewing historic audit logs to determine if a recently

NIST SP 800-53 Rev 5 control RA-3.2 (Use of All-source Intelligence) is defined as follows: RA-3.2

· Use of All-source Intelligence Control Statement: Use all-source intelligence to assist in the analysis of risk. Supplemental Guidance: Use all-source intelligence to assist in the analysis of risk. Organizations employ all-source intelligence to inform engineering, acquisition, and risk management decisions. All-source intelligence consists of information derived from all available sources, including publicly available or open-source information, measurement and signature intelligence, human intelligence, signals intelligence, and imagery intelligence. All-source intelligence is us

Under the FedRAMP High baseline, RA-5.11 (RA-5.11 Public Disclosure Program): FedRAMP High Baseline

· RA-5.11 · Public Disclosure Program Control Statement: Establish a public reporting channel for receiving reports of vulnerabilities in organizational systems and system components. Supplemental Guidance: Establish a public reporting channel for receiving reports of vulnerabilities in organizational systems and system components. The reporting channel is publicly discoverable and contains clear language authorizing good-faith research and the disclosure of vulnerabiliti

NIST SP 800-53 Rev 5 control RA-5.3 (Breadth and Depth of Coverage) is assessed by examining, interviewing, and testing: RA-5.3 · Breadth and Depth of Coverage Control Statement: Define the breadth and depth of vulnerability scanning coverage. Supplemental Guidance: Define the breadth and depth of vulnerability scanning coverage. The breadth of vulnerability scanning coverage can be expressed as a percentage of components within the system, by the particular types of systems, by the criticality of systems, or by the number of vulnerabilities to be checked. Conversely, the depth of vulnerability scanning coverage

C-SCRM practitioners identify, assess, and mitigate cybersecurity risks throughout the supply chain at all levels of their organizations associated with information and communications technology (ICT) products and services. Potential risks include malicious functionality, counterfeit devices, or vulnerabilities derived from poor manufacturing and development practices within the supply chain.

- Risk Assessment: The authenticity and integrity of hardware and software are assessed prior to acquisition and use [ID.RA-09]; Critical suppliers are assessed prior to acquisition [ID.RA-10] - Improvement: Improvements are identified from security tests and exercises, including those done in coordination with suppliers and relevant third parties [ID.IM-02]

Under the FedRAMP High baseline, RA-1 (RA-1 Policy and Procedures): FedRAMP High Baseline · RA-1 ·

Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] risk assessment policy that: 2. Procedures to facilitate the implementation of the risk assessment policy and the associated risk assessment controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the risk assessment policy and procedures; and c

NIST SP 800-53 Rev 5 control RA-5.11 (Public Disclosure Program) is assessed by examining, interviewing, and testing: RA-5.11 · Public Disclosure Program Control Statement: Establish a public reporting channel for receiving reports of vulnerabilities in organizational systems and system components. Supplemental Guidance: Establish a public reporting channel for receiving reports of vulnerabilities in organizational systems and system components. The reporting channel is publicly discoverable and contains clear language authorizing good-faith research and the disclosure of vulnerabilities to the organization.

Under the FedRAMP Low baseline, RA-5.11 (RA-5.11 Public Disclosure Program): FedRAMP Low Baseline ·

RA-5.11 · Public Disclosure Program Control Statement: Establish a public reporting channel for receiving reports of vulnerabilities in organizational systems and system components. Supplemental Guidance: Establish a public reporting channel for receiving reports of vulnerabilities in organizational systems and system components. The reporting channel is publicly discoverable and contains clear language authorizing good-faith research and the disclosure of vulnerabilitie

NIST SP 800-53 Rev 5 control RA-3.3 (Dynamic Threat Awareness) summarizes the requirements for this control: RA-3.3 · Dynamic Threat Awareness Control Statement: Determine the current cyber threat

environment on an ongoing basis using [organization-defined parameter]. Supplemental Guidance: Determine the current cyber threat environment on an ongoing basis using [organization-defined parameter]. The threat awareness information that is gathered feeds into the organization's information security operations to ensure that procedures are updated in response to the changing threat environment. For example

NIST SP 800-53 Rev 5 control RA-3.3 (Dynamic Threat Awareness) is defined as follows: RA-3.3 · Dynamic Threat Awareness Control Statement: Determine the current cyber threat environment on an ongoing basis using [organization-defined parameter]. Supplemental Guidance: Determine the current cyber threat environment on an ongoing basis using [organization-defined parameter]. The threat awareness information that is gathered feeds into the organization's information security operations to ensure that procedures are updated in response to the changing threat environment. For example, at higher threat levels, organizations may change the privilege or authentication thresholds requ

NIST SP 800-171 Rev 3 control 03.11.01 (03.11.01 Risk Assessment) is assessed by examining the following: Assessment Objectives: - the risk (including supply chain risk) of unauthorized disclosure resulting from the processing, storage, or transmission of CUI is assessed. - risk assessments are updated [organization-defined parameter].

Control RA-9: CRITICALITY ANALYSIS Control: Identify critical system components and functions by performing a criticality analysis for [Assignment: organization-defined systems, system components, or system services] at [Assignment: organization-defined decision points in the system development life cycle]. Discussion: Not all system components, functions, or services necessarily require significant protections. For example, criticality analysis is a key tenet of supply chain risk management and informs the prioritization of protection activities. The identification of critical system components and functions considers applicable laws, executive orders, regulations, directives, policies, standards, system functionality requirements, system and component interfaces, and system and component dependencies. Systems engineers conduct a functional decomposition of a system to identify mission-critical functions and components. The functional decomposition includes the identification of organizational missions supported by the system, decomposition into the specific functions to perform those missions, and traceability to the hardware, software, and firmware components that implement those functions, including when the functions are shared by many components within and external to the system. The operational environment of a system or a system component may impact the criticality, including the connections to and dependencies on cyber-physical systems, devices, system-of- systems, and outsourced IT services. System components that allow unmediated access to critical system components or functions are considered critical due to the inherent vulnerabilities that such components create. Component and function criticality are assessed in terms of the impact of a component or function failure on the organizational missions that are supported by the system that contains the components and functions.

Under the FedRAMP Moderate baseline, RA-5.11 (RA-5.11 Public Disclosure Program): FedRAMP Moderate Baseline · RA-5.11 · Public Disclosure Program Control Statement: Establish a public reporting channel for receiving reports of vulnerabilities in organizational systems and system components. Supplemental Guidance: Establish a public reporting channel for receiving reports of vulnerabilities in organizational systems and system components. The reporting channel is publicly discoverable and contains clear language authorizing good-faith research and the disclosure of vulnerabi

Related Controls: RA-03, RA-03(01), SR-06 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.11.01.b [Assignment: organization- defined frequency] at least every 12 months, or when there are significant1 incidents or significant1 changes to risks Risk Assessment 3.11.2 System Vulnerability Management a. Monitor and scan the system for vulnerabilities [Assignment: organization-defined frequency] (03.11.02.a) and when new vulnerabilities affecting the system are identified. b. Remediate system vulnerabilities within [Assignment: organization-defined response times] (03.11.02.b). c. Update system vulnerabilities to be scanned [Assignment: organization-defined frequency] (03.11.02.c) and when new vulnerabilities are identified and reported. Related Controls: RA-05, RA-05(02) ODP Values ODP Identifier ODP Assignment Text ODP Value 03.11.02.a [Assignment: organization- defined frequency] at least monthly, or when there are significant1 incidents or significant1 changes to risks 03.11.02.b [Assignment: organization- defined response times] thirty (30) days from date of discovery for high-risk vulnerabilities (including both critical and high); 90 days from date of discovery for moderate-risk vulnerabilities; and 180 days

from date of discovery for low-risk vulnerabilities 03.11.02.c [Assignment: organization-defined frequency] no more than 24 hours prior to running the scans

From the NIST SP 800-172 Rev 3 Final Public Draft: PROTECTION STRATEGY PRA ADVERSARY EFFECTS Preclude (Preempt) REFERENCES Source Control: RA-09 NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 03.11.11E Discoverable Information 1612

NIST SP 800-53 Rev 5 control RA-3.1 (Supply Chain Risk Assessment) is assessed by examining, interviewing, and testing: RA-3.1 · Supply Chain Risk Assessment Control Statement: (a) Assess supply chain risks associated with [organization-defined parameter] ; and (b) Update the supply chain risk assessment [organization-defined parameter] , when there are significant changes to the relevant supply chain, or when changes to the system, environments of operation, or other conditions may necessitate a change in the supply chain. Supplemental Guidance: (a) Assess supply chain risks associated with [organization-defin

NIST SP 800-53 Rev 5 control RA-6 (Technical Surveillance Countermeasures Survey) summarizes the requirements for this control: RA-6 · Technical Surveillance Countermeasures Survey Control Statement: Employ a technical surveillance countermeasures survey at [organization-defined parameter] [organization-defined parameter]. Supplemental Guidance: Employ a technical surveillance countermeasures survey at [organization-defined parameter] [organization-defined parameter]. A technical surveillance countermeasures survey is a service provided by qualified personnel to detect the presence of technical surveillance devices and

Under the FedRAMP High baseline, RA-2 (RA-2 Security Categorization): FedRAMP High Baseline · RA-2 · Security Categorization Control Statement: a. Categorize the system and information it processes, stores, and transmits; b. Document the security categorization results, including supporting rationale, in the security plan for the system; and c. Verify that the authorizing official or authorizing official designated representative reviews and approves the security categorization decision. Supplemental Guidance: a. Categorize the system and information it processe

NIST SP 800-53 Rev 5 control RA-3.2 (Use of All-source Intelligence) is assessed by examining, interviewing, and testing: RA-3.2 · Use of All-source Intelligence Control Statement: Use all-source intelligence to assist in the analysis of risk. Supplemental Guidance: Use all-source intelligence to assist in the analysis of risk. Organizations employ all-source intelligence to inform engineering, acquisition, and risk management decisions. All-source intelligence consists of information derived from all available sources, including publicly available or open-source information, measurement and signature intelligenc

NIST SP 800-171 Rev 3 control 03.11.02 (03.11.02 Vulnerability Monitoring and Scanning) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Risk Assessment (RA) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

Under the FedRAMP Low baseline, RA-5.2 (RA-5.2 Update Vulnerabilities to Be Scanned): FedRAMP Low Baseline · RA-5.2 · Update Vulnerabilities to Be Scanned Control Statement: Update the system vulnerabilities to be scanned [organization-defined parameter]. Supplemental Guidance: Update the system vulnerabilities to be scanned [organization-defined parameter]. Due to the complexity of modern software, systems, and other factors, new vulnerabilities are discovered on a regular basis. It is important that newly discovered vulnerabilities are added to the list of vulnerabilities to

NIST SP 800-53 Rev 5 control RA-7 (Risk Response) summarizes the requirements for this control: RA-7 · Risk Response Control Statement: Respond to findings from security and privacy assessments, monitoring, and audits in accordance with organizational risk tolerance. Supplemental Guidance: Respond to findings from security and privacy assessments, monitoring, and audits in accordance with organizational risk tolerance. Organizations have many options for responding to risk including mitigating risk by implementing new controls or strengthening existing controls, accepting risk with appro

FedRAMP High Baseline · RA-3 · Risk Assessment Control Statement: a. Conduct a risk assessment, including: 1. Identifying threats to and vulnerabilities in the system; 2. Determining the likelihood and magnitude of harm from unauthorized access, use, disclosure, disruption, modification, or destruction of the system, the information it processes, stores, or transmits, and any related information; and 3. Determining the likelihood and impact of adverse effects on individuals arising from the processing of personally identifiable information; b. Integrate risk assessment results and risk management decisions from the organization and mission or business process perspectives with system-level risk assessments; c. Document risk assessment results in [organization-defined parameter]; d. Review risk assessment results [organization-defined parameter]; e. Disseminate risk assessment results to [organization-defined parameter] ; and f. Update the risk assessment [organization-defined parameter] or when there are significant changes to the system, its environment of operation, or other conditions that may impact the security or privacy state of the system. Supplemental Guidance: a. Conduct a risk assessment, including: 1. Identifying threats to and vulnerabilities in the system; 2. Determining the likelihood and magnitude of harm from unauthorized access, use, disclosure, disruption, modification, or destruction of the system, the information it processes, stores, or transmits, and any related information; and 3. Determining the likelihood and impact of adverse effects on individuals arising from the processing of personally identifiable information; b. Integrate risk assessment results and risk management decisions from the organization and mission or business process perspectives with system-level risk assessments; c. Document risk assessment results in [organization-defined parameter]; d. Review risk assessment results [organization-defined parameter]; e. Disseminate risk assessment results to [organization-defined parameter] ; and f. Update the risk assessment [organization-defined parameter] or when there are significant changes to the system, its environment of operation, or other conditions that may impact the security or privacy state of the system. Risk assessments consider threats, vulnerabilities, likelihood, and impact to organizational operations and assets, individuals, other organizations, and the Nation. Risk assessments also consider risk from external parties, including contractors who operate systems on behalf of the organization, individuals who access organizational systems, service providers, and outsourcing entities. Organizations can conduct risk assessments at all three levels in the risk management hierarchy (i.e., organization level, mission/business process level, or information system level) and at any stage in the system development life cycle. Risk assessments can also be conducted at various steps in the Risk Management Framework, including preparation, categorization, control selection, control implementation, control assessment, authorization, and control monitoring. Risk assessment is an ongoing activity carried out throughout the system development life cycle. Risk assessments can also address information related to the system, including system design, the intended use of the system, testing results, and supply chain-related information or artifacts. Risk assessments can play an important role in control selection processes, particularly during the application of tailoring guidance and in the earliest phases of capability determination. Assessment Objectives: a. Conduct a risk assessment, including: 1. Identifying threats to and vulnerabilities in the system; 2. Determining the likelihood and magnitude of harm from unauthorized access, use, disclosure, disruption, modification, or destruction of the system, the information it processes, stores, or transmits, and any related information; and 3. Determining the likelihood and impact of adverse effects on individuals arising from the processing of personally identifiable information; b. Integrate risk assessment results and risk management decisions from the organization and mission or business process perspectives with system-level risk assessments; c. Document risk assessment results in [organization-defined parameter]; d. Review risk assessment results [organization-defined parameter]; e. Disseminate risk assessment results to [organization-defined parameter] ; and f. Update the risk assessment [organization-defined parameter] or when there are significant changes to the system, its environment of operation, or other conditions that may impact the security or privacy state of the system. FedRAMP Parameter Values: ra-03_odp.01: security assessment report ra-03_odp.02: a document in which risk assessment results are to be documented (if not documented in the security and privacy plans or risk assessment report) is defined (if selected); ra-03_odp.03: at least annually and whenever a significant change occurs ra-03_odp.04: personnel or roles to whom risk assessment results are to be disseminated is/are defined; ra-03_odp.05: annually

NIST SP 800-53 Rev 5 control RA-3.3 (Dynamic Threat Awareness) is assessed by examining, interviewing, and testing: RA-3.3 · Dynamic Threat Awareness Control Statement: Determine the current cyber threat environment on an ongoing basis using [organization-defined parameter]. Supplemental Guidance: Determine the current cyber threat environment on an ongoing basis using

[organization-defined parameter]. The threat awareness information that is gathered feeds into the organization's information security operations to ensure that procedures are updated in response to the changing threat environment. For example

From the NIST SP 800-172 Rev 3 Final Public Draft: analytics capabilities are typically supported by artificial intelligence concepts and machine learning. Examples include automated threat discovery and response (which includes broad-based collection, context-based analysis, and adaptive response capabilities), automated workflow operations, and machine-assisted decision tools. However, sophisticated adversaries may be able to extract information related to analytic parameters and retrain the machine learning to classify malicious activity as benign. Accordingly, machine learning is augmented by human monitoring to help ensure that sophisticated adversaries are not able to conceal their activities. This requirement enhances SP 800-171 requirement 03.11.01. P ROTECTION STRATEGY D LO ADVERSARY EFFECTS Preclude (Expunge), Li

NIST SP 800-53 Rev 5 control RA-5.6 (Automated Trend Analyses) is assessed by examining, interviewing, and testing: RA-5.6 · Automated Trend Analyses Control Statement: Compare the results of multiple vulnerability scans using [organization-defined parameter]. Supplemental Guidance: Compare the results of multiple vulnerability scans using [organization-defined parameter]. Using automated mechanisms to analyze multiple vulnerability scans over time can help determine trends in system vulnerabilities and identify patterns of attack.

FedRAMP High Baseline · RA-5.8 · Review Historic Audit Logs Control Statement: Review historic audit logs to determine if a vulnerability identified in a [organization-defined parameter] has been previously exploited within an [organization-defined parameter]. Supplemental Guidance: Review historic audit logs to determine if a vulnerability identified in a [organization-defined parameter] has been previously exploited within an [organization-defined parameter]. Reviewing historic audit logs to determine if a recently detected vulnerability in a system has been previously exploited by an adversary can provide important information for forensic analyses. Such analyses can help identify, for example, the extent of a previous intrusion, the trade craft employed during the attack, organizational information exfiltrated or modified, mission or business capabilities affected, and the duration of the attack. Assessment Objectives: Review historic audit logs to determine if a vulnerability identified in a [organization-defined parameter] has been previously exploited within an [organization-defined parameter]. FedRAMP Parameter Values: ra-05.08_odp.01: a system whose historic audit logs are to be reviewed is defined; ra-05.08_odp.02: a time period for a potential previous exploit of a system is defined;